

Chapter 4: Threats, Attacks, and Security Troubleshooting

Lecture by Assist. Prof. Dr. Chanankorn Jandaeng

Walailak University

Duration: 90 minutes

Goal:

Understand common types of cyber threats and attacks, identify their network indicators, and learn how to troubleshoot and mitigate them — with demonstration of **ARP Spoofing** in a controlled lab.

Lecture Overview

1. Understanding Cyber Threats
2. Common Attack Categories
3. Malware: Types and Behaviors
4. Denial of Service (DoS) Attacks
5. Man-in-the-Middle (MITM) Attacks
6. Security Misconfiguration Issues
7. Demonstration: ARP Spoofing and Troubleshooting
8. Summary and Best Practices

1. Understanding Cyber Threats

Definition:

A *threat* is any circumstance or event that has the potential to adversely impact organizational operations or assets through unauthorized access, destruction, or disclosure.

Classification:

- **Intentional:** Hackers, insiders, cybercriminal groups
- **Unintentional:** Misconfigurations, software bugs, human errors
- **Environmental:** Power failure, natural disaster

Threat Components

Component	Description	Example
Threat Actor	Individual or group initiating attack	Hacker, insider, botnet controller
Vector	Method of exploitation	Phishing, malware, network scanning
Target	Asset or system attacked	Database, endpoint, user credentials

2. Common Attack Categories

Category	Description	Example
Reconnaissance	Information gathering	Port scanning, banner grabbing
Access/Exploitation	System compromise	Credential theft, code injection
Denial/Disruption	Service unavailability	DDoS, network flood
Evasion	Avoiding detection	Encryption, steganography
Exfiltration	Stealing data	Uploading confidential files

Attack Lifecycle (Cyber Kill Chain)

1. Reconnaissance
2. Weaponization
3. Delivery
4. Exploitation
5. Installation
6. Command & Control
7. Actions on Objectives

Instructor Note:

Explain how network monitoring can detect anomalies in several stages (3–6).

3. Malware: Types and Behaviors

Malware (Malicious Software):

Programs designed to disrupt, damage, or gain unauthorized access to systems.

Type	Description	Typical Behavior
Virus	Attaches to legitimate files	Requires execution to spread
Worm	Self-replicating via network	Consumes bandwidth, spreads fast
Trojan	Masquerades as trusted software	Opens backdoor access
Spyware	Monitors user activity	Steals credentials, keystrokes
Ransomware	Encrypts data for ransom	Demands payment to decrypt
Rootkit	Hides system compromise	Alters kernel or boot process

Malware Indicators (Network-Level)

- Unusual outbound connections
- Frequent DNS requests to unknown domains
- High CPU/network usage
- Unexpected file uploads/downloads
- Suspicious TLS certificates or beaconing patterns

Display Filter Example (Wireshark):

`tcp.port == 4444` — C2 communication pattern.

Troubleshooting Malware Incidents

1. **Identify** unusual process or network behavior
2. **Isolate** affected device from network
3. **Preserve** logs and evidence for forensics
4. **Analyze** using antivirus or sandbox tools
5. **Remediate** through patching or reimaging
6. **Recover and monitor** for reinfection

Key Toolset:

- Sysinternals, Process Explorer, Wireshark, YARA rules

4. Denial of Service (DoS) Attacks

Definition:

An attack that overwhelms resources or bandwidth, making services unavailable to legitimate users.

Types:

- **Volumetric:** Network floods (UDP, ICMP)
- **Protocol:** SYN floods, Ping of Death
- **Application Layer:** HTTP floods, slowloris attacks

DoS vs DDoS

Type	Source	Description
DoS	Single attacker	Floods single target
DDoS	Distributed (botnet)	Thousands of hosts attack simultaneously

Example:

Botnet sending excessive HTTP GET requests to a web server.

Troubleshooting DoS Symptoms

Indicator	Possible Cause	Verification
High bandwidth usage	Volumetric flood	Check router/switch logs
Service timeout	Resource exhaustion	Analyze server logs
Multiple SYN without ACK	SYN flood	Wireshark: <code>tcp.flags.syn==1 && tcp.flags.ack==0</code>

Troubleshooting DoS Symptoms

Countermeasures:

- Rate limiting
- SYN cookies
- Load balancers / CDNs
- Blackhole routing

5. Man-in-the-Middle (MITM) Attacks

Concept:

Attacker secretly relays or alters communication between two parties who believe they are communicating directly.

Common Techniques:

- ARP Spoofing / Poisoning
- DNS Spoofing
- SSL Stripping
- Session Hijacking

Goal:

Steal credentials, inject data, or manipulate traffic.

MITM Network Flow

Victim (A) → Attacker (M) → Server (B)

1. M impersonates B to A
2. M intercepts packets
3. M forwards traffic, optionally modifying data

Result:

Victim trusts attacker's MAC/IP and sends traffic through them.

Detecting MITM Activity

- Inconsistent ARP table entries
- Duplicate IP/MAC addresses
- Unexpected SSL certificate warnings
- High volume of retransmissions or latency

Command Example:

```
arp -a
```

Check if gateway IP maps to unfamiliar MAC address.

Troubleshooting MITM Attacks

1. Verify ARP cache (`arp -a`)
2. Clear cache (`arp -d *`)
3. Reconnect and validate correct gateway
4. Monitor with Wireshark or IDS for spoofed replies
5. Implement network segmentation and static ARP entries for critical nodes

6. Security Misconfiguration

Definition:

Incorrect or insecure system setup that exposes vulnerabilities.

Common Examples:

- Default passwords not changed
- Unused ports and services left open
- Improper file permissions
- Outdated firmware or software
- Missing HTTPS enforcement

Detecting Misconfigurations

- Run **Nmap** to identify open ports
- Check for **banner leaks** or **version exposure**
- Review **firewall and ACL policies**
- Inspect **server configuration files** (e.g., Apache, Nginx)

Mitigation:

- Apply configuration baselines (CIS Benchmarks)
- Regular audits and patch management
- Least privilege enforcement

7. Demonstration: ARP Spoofing (Lab Overview)

Objective:

Demonstrate how an attacker can perform **ARP Spoofing** and how to detect and mitigate it.

Step 1: Concept Recap

ARP (Address Resolution Protocol):

Maps IP addresses to MAC addresses within a LAN.

ARP Spoofing Principle:

Attacker sends **false ARP replies**, associating their MAC with the gateway's IP → intercepts all victim traffic.

Step 2: Lab Environment

Role	Device	Example IP
Victim	Windows / Linux client	192.168.1.10
Gateway	Router	192.168.1.1
Attacker	Kali Linux	192.168.1.20

Tools:

`arp spoof` , `ettercap` , `wireshark`

Step 3: Attack Demonstration (Controlled)

Command (on Kali):

```
sudo arpspoof -i eth0 -t 192.168.1.10 192.168.1.1  
sudo arpspoof -i eth0 -t 192.168.1.1 192.168.1.10
```

Effect:

- Victim's ARP cache now points to attacker's MAC as gateway.
- Attacker can capture packets using Wireshark or `tcpdump`.

Step 4: Detection and Troubleshooting

On Victim Machine:

```
arp -a
```

Output Example:

```
192.168.1.1 at 00:11:22:33:44:55 (should be 00:AA:BB:CC:DD:EE)
```

Symptoms:

- Slower connection
- Unusual certificate warnings
- Duplicate MAC notifications in IDS logs

Step 5: Mitigation Strategies

Method	Description
Static ARP entries	Manually bind gateway IP to MAC
Dynamic ARP Inspection (DAI)	Switch feature to validate ARP packets
Segmentation & VLANs	Limit broadcast domain
Encrypted Protocols	HTTPS, SSH to prevent data theft
Network Monitoring	Alerts on duplicate IP/MAC mappings

Step 6: Ethical and Safety Considerations

- Conduct ARP spoofing **only in isolated lab networks**
- Always notify stakeholders before simulation
- Use attacks purely for educational and defensive learning purposes

8. Summary and Best Practices

Key Concepts Covered:

- Malware, DoS, MITM, Misconfiguration threats
- ARP spoofing mechanisms and detection
- Troubleshooting approach: *Observe → Isolate → Analyze → Remediate*

Best Practices:

- Maintain updated systems
- Use layered defense (firewalls, IDS/IPS, monitoring)
- Train users on security hygiene
- Document and test response procedures regularly

Reflection & Discussion

- Which attack vector is most common in university networks?
- How can we identify ARP spoofing early using network monitoring tools?
- What configuration checks can prevent simple but dangerous misconfigurations?

End of Lecture

Assist. Prof. Dr. Chanankorn Jandaeng

Walailak University

Contact: chatchanan.ja@mail.wu.ac.th